

Hybrid Post-Quantum Key Exchange for WireGuard: Integrating ML-KEM into a Production Rust Userspace Implementation

Mihai-Cristian Farcaş
Babeş-Bolyai University
Cluj-Napoca, Romania
`mihaicristianfarcas@gmail.com`

Sergiu Adrian Darabant
Babeş-Bolyai University
Cluj-Napoca, Romania
`sergiu.darabant@ubbcluj.ro`

July 27, 2026

Abstract

WireGuard’s key exchange relies entirely on X25519, which Shor’s algorithm will break once a cryptographically relevant quantum computer exists; under the harvest-now-decrypt-later threat model, traffic recorded today is already at risk. With ML-KEM standardized as FIPS 203 in August 2024, the question for deployed VPNs is no longer which post-quantum primitive to adopt but what adopting one actually costs. This paper answers that question for WireGuard by integrating ML-KEM-768 alongside X25519 into the Noise IK handshake of BoringTun, Cloudflare’s production Rust userspace WireGuard, following the established concatenate-then-KDF hybrid pattern. The intervention is deliberately minimal: roughly 800 added lines behind a Cargo feature flag, about a quarter of them tests, with the data-transport path untouched and no kernel modifications required. A simpler baseline that injects ML-KEM-derived keying material into WireGuard’s existing preshared-key (PSK) slot is also implemented as a lower bound on engineering effort. Both approaches are evaluated on three platforms (Apple M4, Raspberry Pi 5, AMD Ryzen 7 5700X), measuring handshake latency, transport throughput, primitive-level microbenchmarks, MTU behaviour, RTT/loss tolerance, per-peer memory footprint, and denial-of-service asymmetry under a saturating handshake flood. The measured cost is concentrated on the wire rather than in the CPU: handshake cryptography stays under half a millisecond of added latency even on the Raspberry Pi, throughput is unchanged, per-peer memory grows by a fixed 6.4 KB, and WireGuard’s MAC1 flood defence carries over intact, while the handshake grows by 2272 bytes and survives IP-layer fragmentation across the measured MTU range. The construction is secure as long as at least one of X25519 or ML-KEM remains unbroken, and provides per-session forward secrecy that the PSK-slot approach cannot match. The implementation is further validated end-to-end over the public internet, establishing hybrid tunnels between Romania and a US-East cloud host and round-tripping integrity-checked payloads through them. To our knowledge, this is the first FIPS 203-compliant hybrid WireGuard implementation built on a production Rust codebase.

Keywords: Post-Quantum Cryptography, WireGuard, ML-KEM, FIPS 203, Hybrid Key Exchange, Noise Protocol, Rust, BoringTun.

1 Introduction

Public-key cryptography underpins virtually all secure communication on the internet: VPN tunnels, TLS handshakes, SSH connections all depend on the computational hardness of problems like integer factorization and the elliptic-curve discrete logarithm. This assumption has held for decades, but will not hold forever. Shor’s polynomial-time quantum algorithm [22] solves both problems, so a sufficiently large fault-tolerant quantum computer would break RSA and elliptic-curve cryptography. Current estimates put the cost of factoring RSA-2048 at roughly millions of physical qubits with today’s error-correction techniques [8], and hardware roadmaps from IBM, Google, and others suggest that scale could be reached within the next decade or two.

In response, NIST launched its Post-Quantum Cryptography (PQC) Standardization Project in 2016 and finalized the first round of standards in August 2024: FIPS 203 (ML-KEM, key encapsulation) [17], FIPS 204 (ML-DSA, digital signatures), and FIPS 205 (SLH-DSA, hash-based signatures). For VPN key exchange, ML-KEM is the directly relevant standard. NIST has also set a hard timeline: classical key exchange algorithms are to be deprecated by 2030 and disallowed entirely by 2035 [18].

WireGuard [4] is among the most important migration targets. Since 2017 it has largely replaced IPsec and OpenVPN as the go-to VPN protocol, thanks to its small codebase, strong performance, and easy auditability. It ships in the Linux kernel, runs on every major operating system, and is deployed at scale by Cloudflare, Mullvad, NordVPN, Tailscale, and many enterprises. WireGuard’s cryptographic design is deliberately opinionated, however: a fixed cipher suite with no negotiation. This rigidity is a security advantage (cipher agility has been a recurring source of vulnerabilities in TLS and IPsec), but it makes migration harder, since there is no built-in way to swap in a different key exchange algorithm.

WireGuard does provide two natural handles for post-quantum augmentation. The first is the preshared-key (PSK) slot, a 256-bit symmetric key that is mixed into the handshake’s key derivation chain. If a post-quantum KEM is used out-of-band to establish this PSK, the resulting handshake is quantum-resistant against passive adversaries, at the cost of requiring separate key distribution infrastructure. The second approach is to modify the Noise IK handshake itself, embedding ML-KEM operations alongside the existing X25519 exchange so that both shared secrets contribute to the final session key in every handshake. The latter is what we call the *full hybrid* approach.

Contributions. This paper makes four contributions:

1. A **full hybrid handshake** in a production codebase: a modified BoringTun that runs both X25519 and ML-KEM-768 in every handshake, mixing both shared secrets into the Noise chaining key via HMAC-BLAKE2s. The change is deliberately small (roughly 800 added lines across seven files, about a quarter of them tests, all behind a Cargo feature flag) and leaves the data-transport phase untouched.
2. A **PSK-slot baseline**: a small CLI tool that performs ML-KEM-768 key encapsulation between two peers out-of-band and feeds the resulting 256-bit key into BoringTun’s `preshared_key` field, as a lower bound on engineering effort.
3. A **three-platform empirical evaluation** on Apple M4, Raspberry Pi 5, and AMD Ryzen 7 5700X, covering handshake latency, transport throughput, primitive-level microbenchmarks, an ML-KEM parameter-set sweep, a path-MTU sweep, an RTT×loss matrix, per-peer memory footprint, and DoS asymmetry under a saturating handshake flood, complemented by an end-to-end validation over a real transcontinental internet path.
4. An **informal security argument** comparing the two approaches, with a discussion of where each one fits in practice and what is required to extend authentication to the post-quantum

setting.

The novelty here is one of engineering and evidence rather than cryptographic construction. The hybrid follows the well-understood concatenate-then-KDF combiner, and the goal is not the ultimate production-ready post-quantum VPN; formally verified protocol designs exist for that ambition [9, 13]. The question addressed here is a complementary and, for operators, more immediate one: how invasive is it, really, to put standardized ML-KEM into a deployed WireGuard implementation, and what does it cost across hardware tiers, network conditions, and adversarial load? The answer — a few hundred lines of feature-gated Rust whose overhead is dominated by handshake-message size rather than computation — is the paper’s central result. The security argument is correspondingly informal; a formal proof in the eCK-PFS-PSK model is left as future work.

The rest of the paper is structured as follows. Section 2 covers the relevant background; Section 3 surveys prior work; Section 4 describes the hybrid design; Section 5 the BoringTun integration; Section 6 the security argument; Section 7 the empirical evaluation; Section 8 discusses deployability and future work; and Section 9 concludes.

2 Background

2.1 The quantum threat and HNDL

A quantum computer running Shor’s algorithm could derive an X25519 private key from the corresponding public key and reconstruct any session key derived from it. What makes this urgent before such a machine exists is the *harvest-now-decrypt-later* (HNDL) attack model: an adversary passively records encrypted traffic today — WireGuard handshakes, transport data, all of it — and decrypts it once a quantum computer becomes available. Traffic encrypted today with classical-only key exchange may therefore already be compromised in a meaningful sense.

Symmetric cryptography is largely safe: Grover’s algorithm provides only a quadratic speedup, effectively halving key lengths, so AES-256, ChaCha20-Poly1305, BLAKE2s, and HMAC-based key derivation remain unaffected. The migration problem is confined to the asymmetric key exchange layer.

2.2 WireGuard and the PSK slot

WireGuard [4] is a layer-3 VPN protocol built around a fixed set of modern primitives and a deliberately minimal state machine. The handshake uses the Noise Protocol Framework [19] (the IK pattern) with X25519 for Diffie-Hellman, HKDF [12] for key derivation, ChaCha20-Poly1305 for authenticated encryption, and BLAKE2s for hashing. The handshake produces a 1-RTT session: the initiator sends one message that authenticates its identity and commits an ephemeral key; the responder verifies and replies; both sides derive matching session keys. Sessions rekey after 120 seconds or 2^{60} messages, and all ephemeral keys are zeroed after use.

WireGuard includes an optional 256-bit preshared key (PSK), added specifically as a transitional post-quantum measure: when configured, it is mixed into the handshake’s key derivation chain, so an attacker who breaks X25519 but never obtained the PSK still cannot decrypt the traffic. Its limitations are structural: the PSK is a long-lived static value, not an ephemeral secret, so it provides no forward secrecy for the quantum-resistant component, and its distribution and rotation require an out-of-band channel.

2.3 Noise and the KEM/DH asymmetry

Noise patterns specify the handshake messages and the DH operations performed at each step; a chaining key ck and handshake hash h absorb every DH result, public key, and encrypted payload via HMAC and BLAKE2s, binding all messages into one transcript. The main difficulty

in migrating Noise to PQC is that DH is non-interactive: either party computes the shared secret from the other’s public key, whereas a KEM is directional: one party encapsulates a secret to a specific public key, and only the holder of the corresponding private key can decapsulate it. The handshake flow therefore needs reworking when KEMs are introduced.

2.4 ML-KEM (FIPS 203)

ML-KEM was standardized as FIPS 203 in August 2024 [17]. It is a key encapsulation mechanism derived from CRYSTALS-Kyber [2], whose security rests on the Module Learning With Errors (MLWE) problem [14], exposing the usual three operations (KeyGen, Encaps, Decaps). FIPS 203 specifies three parameter sets (ML-KEM-512, -768, and -1024 at NIST categories 1, 3, 5) with encapsulation-key/ciphertext sizes of 800/768 B, 1184/1088 B, and 1568/1568 B respectively, all producing a 32-byte shared secret; NIST recommends ML-KEM-768 as the default. Thanks to the Number-Theoretic Transform, ML-KEM is computationally cheap on commodity CPUs, often competitive with or faster than elliptic-curve operations, but its keys and ciphertexts are 30–50× larger.

2.5 Hybrid key exchange and concatenate-then-KDF

Hybrid key exchange combines two key agreement algorithms so the resulting key is secure as long as at least one component holds, prudent because ML-KEM, though standardized, has seen far less cryptanalytic scrutiny than X25519. The standard construction is the *concatenate-then-KDF* pattern, formalized in NIST SP 800-56C Rev. 2 [16]: the component shared secrets are concatenated, $Z' = Z||T$, and fed into a single key derivation function. Giacon, Heuer, and Poettering [7] prove the resulting KEM secure as long as either component is secure. The same pattern is used in hybrid TLS 1.3 deployments by Cloudflare and Google and in the IETF hybrid design draft [23].

3 Related Work

PQ-WireGuard (Hülsing et al., 2021). The most directly relevant prior work [11] replaces WireGuard’s X25519 handshake entirely with a KEM-based construction (Classic McEliece for authentication, Saber for ephemeral exchange), proved secure in the eCK-PFS-PSK model and verified in Tamarin. This paper differs in three ways: it is hybrid rather than purely post-quantum, targets NIST-standardized ML-KEM rather than pre-standardization Saber, and works within a production codebase rather than a research prototype.

PQNoise. Angel, Dowling, Hülsing, Schwabe, and Weber [1] give a generic framework for converting Noise patterns into post-quantum equivalents using KEMs, with new `ekem/skem` tokens replacing the DH tokens. The hybrid construction described here can be viewed as a variant of their `pqIK` pattern augmented with classical DH.

Hybrid-WireGuard (Lafourcade et al., 2025). Lafourcade, Mahmoud, and Ruhault [13] revisit PQ-WireGuard with formal analysis in SapiC+, fix a UKS attack (PQ-WireGuard $\star$), and propose Hybrid-WireGuard, combining WireGuard’s DH secrets with the KEM secrets of PQ-WireGuard $\star$. They emphasize that MTU constraints sharply limit which KEMs fit WireGuard’s handshake within the IPv6 minimum of 1280 bytes. The present work is complementary rather than overlapping: theirs proves a hybrid protocol secure, this paper implements one inside BoringTun, accepts the larger messages (relying on IP fragmentation rather than constraining the parameter set), and measures the consequences on real hardware.

Rosenpass. Rosenpass [20, 21] turns the PSK-slot idea into a continuously running Rust daemon, refreshing post-quantum PSKs (Classic McEliece + Kyber-512) every two minutes. It is structurally similar to the PSK baseline here, with continuous operation instead of one-time injection, and shares the forward-secrecy limitation of any PSK-based approach.

ExpressVPN’s production PSK delivery. Membrey and Beyel [15] describe a production PSK-slot deployment that delivers WireGuard PSKs over ML-KEM hybrid TLS 1.3, live across ExpressVPN’s infrastructure at a cost of 15–20 ms of connection establishment and no steady-state throughput penalty.

Revised PQ-WireGuard with reinforced KEMs. Concurrent work by Hashimoto, Katsumata, Niot, and Wiggers (IEEE S&P 2026) [9] introduces *reinforced KEMs*; their Rebar construction eliminates Classic McEliece static keys on the server, cutting its public-key memory by 190–390×, and represents the state of the art in purely post-quantum WireGuard design.

4 Design

4.1 Design goals

The design is guided, in rough order of priority, by: **correctness** (the hybrid must produce the same session keys at both endpoints and fail securely if either component fails), **security** (the construction must be secure as long as at least one of X25519 or ML-KEM-768 remains unbroken, and preserve session-key secrecy, perfect forward secrecy, replay resistance, and DoS resistance), **compatibility** (the PSK-slot baseline must coexist with unmodified WireGuard; the hybrid requires explicit configuration of both parties), **deployability** (no kernel modifications required), and **performance** (overhead acceptable on Raspberry-Pi-class hardware).

4.2 The PSK-slot baseline

The PSK-slot approach is the minimal intervention: before any WireGuard session is established, the two peers run an out-of-band ML-KEM-768 exchange. One peer generates a keypair and sends the encapsulation key to the other, who runs ML-KEM.Encaps and returns the ciphertext; both sides now hold the same 32-byte secret K and configure it as their interface’s `reshared_key`. The WireGuard handshake then proceeds exactly as in the vanilla case, mixing K into its HMAC-BLAKE2s key derivation chain and giving every session under that PSK a quantum-resistant symmetric layer.

The limitations are the PSK mechanism’s own: the ML-KEM exchange is one-time rather than per-session, so the quantum-resistant component has no forward secrecy: a PSK compromised after the fact exposes all traffic from sessions that used it, and the PSK must be distributed before any session can be established. The clear advantage: zero changes to WireGuard itself.

4.3 The hybrid handshake

The full hybrid integrates ML-KEM-768 directly into the Noise IK handshake. The design follows the concatenate-then-KDF pattern endorsed by NIST SP 800-56C Rev. 2 [16] and is structurally similar to the hybrid constructions in TLS 1.3 [23].

Initiator (first message). The initiator generates an ephemeral X25519 keypair as in standard WireGuard. It also generates a fresh ML-KEM-768 keypair for this session: encapsulation key ek_i and decapsulation key dk_i . The 1184-byte ek_i is appended to the initiator’s first message, after the standard WireGuard fields but before the MAC fields, so that MAC1 and MAC2

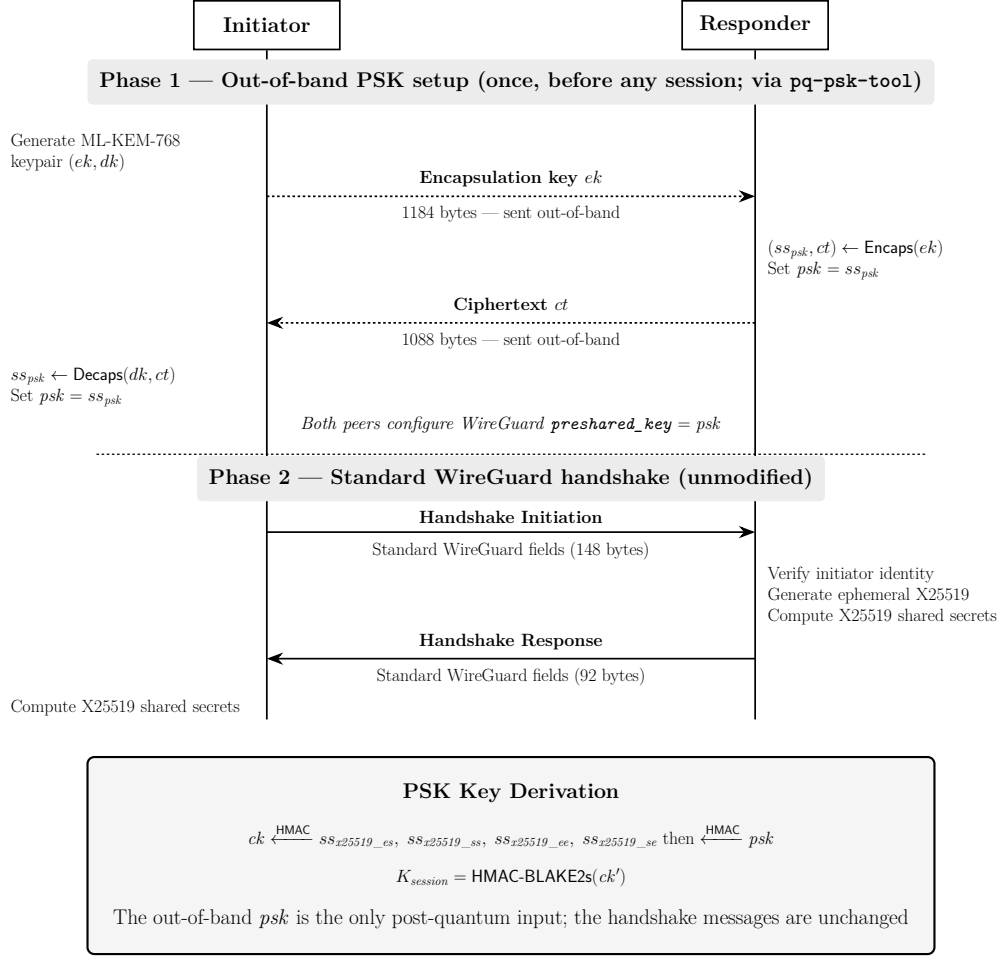


Figure 1: PSK-Slot baseline: out-of-band ML-KEM exchange and PSK injection.

cover the entire message, including the ML-KEM material. This ensures the cookie-based DoS-resistance mechanism extends to the post-quantum payload.

Responder (second message). The responder processes the X25519 portion of the handshake as in standard WireGuard. It also reads ek_i from the first message, runs $\text{ML-KEM.Encaps}(ek_i)$ to produce a ciphertext ct (1088 bytes) and shared secret ss_{kem} , and appends ct to the response message.

Initiator decapsulation. The initiator reads ct from the response and runs $\text{ML-KEM.Decaps}(dk_i, ct)$, recovering ss_{kem} . Both peers now hold the same ss_{kem} .

Combined key derivation. Both parties derive the final session keys by sequentially mixing each shared secret into the Noise chaining key ck via HMAC-BLAKE2s, following the same pattern WireGuard already uses for DH results. The four X25519 shared secrets from the Noise IK pattern ($ss_{x25519_es}, ss_{x25519_ss}, ss_{x25519_ee}, ss_{x25519_se}$) are mixed first, exactly as in vanilla WireGuard. Then the ML-KEM shared secret ss_{kem} is mixed in as an additional step:

$$temp = \text{HMAC-BLAKE2s}(ck, ss_{kem}), \quad ck' = \text{HMAC-BLAKE2s}(temp, 0x01).$$

The handshake hash h is also updated to include the ML-KEM material (both the encapsulation key and ciphertext), binding it to the Noise transcript. The PSK mixing step then proceeds

on ck' exactly as in standard WireGuard (using a zero PSK if none is configured). The data-transport phase is unchanged.

This sequential mixing is structurally equivalent to the concatenate-then-KDF pattern from NIST SP 800-56C: each shared secret contributes independently to the chaining key, and the final session keys depend on all components.

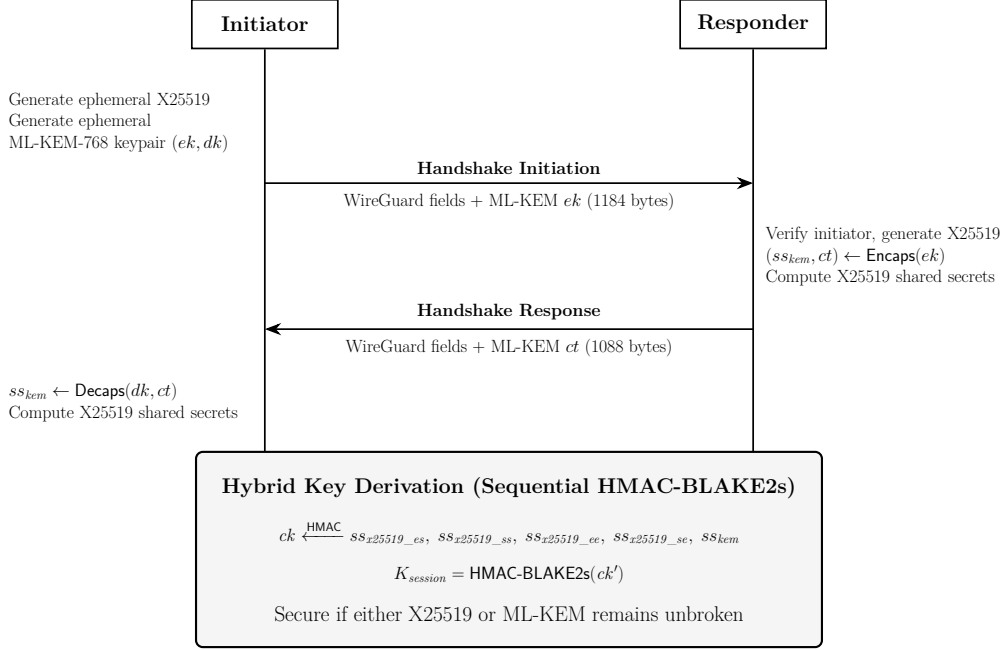


Figure 2: The full hybrid handshake: integrated ML-KEM-768 alongside X25519.

Two properties follow. **Per-session forward secrecy** comes from both components: the X25519 ephemeral key is fresh for each handshake, and so is the ML-KEM keypair, so ss_{kem} is unique to each session. The construction is also **hybrid-secure**: if ML-KEM is completely broken, the session key still depends on the X25519 exchange and cannot be recovered without breaking X25519 too. The converse also holds.

4.4 Message sizes and MTU

Vanilla WireGuard’s handshake initiation is 148 bytes and the response 92 bytes. ML-KEM-768 adds the 1184-byte encapsulation key to the initiation and the 1088-byte ciphertext to the response, giving 1332-byte and 1180-byte hybrid messages. On typical 1500-byte Ethernet paths both fit in a single UDP datagram; the initiation, however, exceeds the 1280-byte IPv6 minimum MTU, so on constrained paths it fragments at the IP layer — which is unreliable in the wild, since some middleboxes drop fragments. The implementation deliberately accepts IP-level fragmentation rather than complicating the protocol; Section 7.5 measures the consequences, and alternative strategies (application-level segmentation, PMTUD-driven parameter negotiation) are discussed as future work in Section 8.

5 Implementation

5.1 BoringTun and the technology stack

BoringTun [3] is Cloudflare’s userspace WireGuard implementation, written in Rust and deployed on millions of iOS and Android devices and on thousands of Cloudflare Linux servers. It ships as a library crate (`boringtun`) and a CLI binary (`boringtun-cli`). The handshake

module implements the Noise IK pattern, manages per-peer state machines, performs X25519 operations via the `x25519-dalek` crate, and uses HMAC-BLAKE2s for chaining key evolution. The transport module (ChaCha20-Poly1305) is not touched. Rust’s ownership model rules out the memory-safety bugs that have historically plagued cryptographic code, and makes pulling in pure-Rust crates from the RustCrypto ecosystem straightforward, with no C FFI boundary.

ML-KEM operations use the `ml-kem` crate (version 0.3.0-rc.0) from RustCrypto, a pure-Rust, `no_std` implementation of FIPS 203 tested against the NIST Known-Answer-Test vectors, which runs on constrained targets like the Raspberry Pi without any C FFI. Key derivation reuses BoringTun’s existing HMAC-BLAKE2s extraction pattern; no separate HKDF or SHA-256 construction is introduced. The only dependency friction is an RNG version skew (`ml-kem` needs `rand_core` 0.10, BoringTun ships 0.6), resolved with Cargo’s package-renaming feature so both versions coexist.

5.2 Handshake module modifications

The entire intervention amounts to roughly 800 added and 5 removed lines across seven files, and about 220 of the added lines are tests. The bulk sits in the handshake module (~380 lines) and the packet parser (~160 lines of constants, message formats, and dispatch); the rate limiter, error enum, device layer, and `Cargo.toml` absorb the remaining few dozen. The session/transport module is not modified at all. All post-quantum code is conditionally compiled behind a Cargo feature flag (`pq`), which gates the `ml-kem` dependency chain as well as all PQ-related message types, state fields, and handshake methods; vanilla builds compile no additional dependencies, change no code paths, and keep an identical binary size.

State extension. The `HandshakeState` structure is extended to carry the minimal ML-KEM material each side needs across handshake steps. On the initiator side, only the `DecapsulationKey768` is stored, so the response can later be decapsulated; the encapsulation key is serialized into the initiation message and then dropped. On the responder side, only the received encapsulation key is stored, so encapsulation can be performed when the response is built; the resulting ciphertext is written directly into the response message rather than retained in state.

Message construction. When the initiator builds the initiation message, it generates a fresh ML-KEM-768 keypair and appends the 1184-byte encapsulation key after the standard WireGuard fields, mixing it into the handshake hash h . When the responder processes the initiation, it extracts the encapsulation key, validates its length, runs `Encaps` to produce ct and ss_{kem} , and appends the 1088-byte ct to the response, again mixing it into h .

Session-key derivation. At the end of the handshake, both parties mix ss_{kem} into the chaining key via the additional HMAC-BLAKE2s step described in Section 4, before proceeding to PSK mixing and final session key derivation. A new error variant (`MLKemDecapsulationFailed`) handles decapsulation failures gracefully, causing the handshake to abort without leaking state.

New message types. Two new message types are introduced: type 5 for PQ handshake initiation (1332 bytes) and type 6 for PQ handshake response (1180 bytes). The packet parser dispatches on message type and size, routing PQ messages to the PQ handshake methods. Vanilla builds reject these message types with `InvalidPacket`, ensuring graceful interoperability.

5.3 PSK-slot baseline implementation

The PSK-slot baseline is implemented as a separate Rust CLI binary, `pq-psk-tool`, independent of BoringTun. It uses the same `ml-kem` crate and provides three subcommands (`keygen`, `encaps`, `decaps`) implementing the manual three-step ML-KEM-768 exchange of Section 4, with the encapsulation key, ciphertext, and resulting PSK carried as base64 files exchanged out-of-band.

Both peers then install the derived PSK with `wg set <iface> peer <PUBKEY> preshared-key psk.b64`.

5.4 Test harness

The `noise::tests` module contains conditionally compiled unit tests for both handshake paths: PQ message-size validation, full PQ handshakes including keepalive, end-to-end data transport, simultaneous PQ + PSK operation, and verification that a vanilla build rejects PQ message types. A separate shell script automates operational loopback testing on macOS.

6 Security Analysis

The security goals for the hybrid handshake are the same as for vanilla WireGuard, as established by Dowling and Paterson’s computational proof [6] and Donenfeld and Milner’s symbolic Tamarin proof [5], and extended to the post-quantum setting by PQ-WireGuard [11] and Hybrid-WireGuard [13]. We summarize the goals informally and give a hybrid security argument; a fully formal proof in the eCK-PFS-PSK model or in a Sapic+/Tamarin model is left as future work.

Goals. **Session-key secrecy:** an adversary who does not corrupt either party’s long-term or ephemeral secrets cannot distinguish the established session key from a random value. **Perfect forward secrecy:** compromise of long-term static keys does not allow decryption of past sessions; each session uses fresh ephemeral keypairs (both X25519 and ML-KEM). **Post-quantum forward secrecy:** a quantum adversary who breaks X25519 after the session cannot decrypt past traffic, since doing so also requires breaking ML-KEM. **Authenticity:** both initiator and responder verify each other’s identity via X25519 static keys (classical, not post-quantum, in this design). **DoS resistance:** the WireGuard cookie mechanism is preserved; handshake-init messages with invalid MAC1 are rejected without state allocation. **Replay resistance:** the handshake transcript, extended to include the ML-KEM material, prevents replay attacks.

Hybrid argument. Let $ss_{\text{classical}}$ denote the combined X25519 shared secrets and ss_{kem} the ML-KEM-768 shared secret. After the classical exchange, ck already incorporates $ss_{\text{classical}}$. The ML-KEM secret is then mixed in as $ck' = \text{HMAC-BLAKE2s}(\text{HMAC-BLAKE2s}(ck, ss_{\text{kem}}), 0x01)$, and the session keys K are derived from ck' after the PSK mixing step.

Claim: K is computationally indistinguishable from a random key as long as either $ss_{\text{classical}}$ is pseudorandom (i.e., X25519 is secure) or ss_{kem} is pseudorandom (i.e., ML-KEM-768 is IND-CCA2 secure).

This follows from the security of HMAC-BLAKE2s as a PRF: if either input to the chaining key is uniformly random and independent of the adversary’s view, the chaining-key output and the derived session keys are computationally indistinguishable from random. The sequential mixing of independent shared secrets is structurally equivalent to the concatenate-then-KDF pattern; the formal proof is a standard hybrid argument, which Giacon, Heuer, and Poettering [7] give for the concatenation combiner.

In the HNDL threat model, the adversary captures the handshake transcript — X25519 public keys and ML-KEM ciphertext included. With a quantum computer it can recover $ss_{\text{classical}}$ from the X25519 keys; to also recover ss_{kem} it must solve the ML-KEM decapsulation problem, which is the IND-CCA2 security problem for ML-KEM, believed hard for both classical and quantum adversaries under the MLWE assumption.

Forward secrecy. In the PSK-slot baseline the ML-KEM exchange happens once, out-of-band, and the PSK is reused across many sessions: a PSK compromised after the fact retroactively exposes all of them, even to a purely classical adversary. In the full hybrid, (ek_i, dk_i) is generated fresh for every handshake and ct encapsulates ss_{kem} specifically for that session. Once dk_i has been zeroed from memory (consistent with WireGuard’s existing practice for ephemeral keys), no information remains that would allow recovery of ss_{kem} .

Classical authentication. A limitation shared with most practical hybrid WireGuard proposals is that authentication stays classical. A quantum adversary could, in principle, compute the static X25519 private key from the static public key and impersonate either party in new sessions. However, authentication cannot be retroactively broken (the static key affects only the handshake transcript, not session data), and the HNDL threat for past sessions is mitigated by the ML-KEM component. Extending authentication to ML-DSA [18] is identified as future work in Section 8.

7 Evaluation

The hybrid handshake is evaluated along several axes: handshake latency, transport throughput, primitive microbenchmarks, an ML-KEM parameter-set sweep, a path-MTU sweep, an RTT×loss matrix, per-peer memory footprint, and DoS asymmetry under a saturating handshake flood; Section 7.9 closes with an end-to-end validation over a real transcontinental internet path. All controlled measurements use three platforms across two architectures:

- **Apple MacBook Pro M4 (Apple Silicon):** ARMv8.5-A, 14-core, 24 GB RAM, macOS Tahoe. The development machine and high-performance reference.
- **Raspberry Pi 5 (Broadcom BCM2712, Cortex-A76):** ARM64, 4-core, 8 GB RAM, Raspberry Pi OS Lite (64-bit). A stand-in for resource-constrained embedded/edge deployments.
- **AMD Ryzen 7 5700X:** 8-core / 16-thread, AVX2, Ubuntu 26.04 inside WSL2 on Windows. Included so the implementation is not measured exclusively on ARM, and so that any ARM-specific artefact in the `x25519-dalek` backend (which lacks a NEON port) shows up against an x86 control.

Three configurations are compared: **Vanilla** (unmodified BoringTun, no PSK), **PSK-slot** (BoringTun with a WireGuard PSK derived from a one-time ML-KEM-768 exchange via `pq-psk-tool`), and **Hybrid** (modified BoringTun with the full X25519 + ML-KEM-768 hybrid handshake). The `pq` Cargo feature is a compile-time switch: when the binary is built with `-features pq`, *all* tunnels go through the hybrid handshake path. Vanilla and PSK-slot numbers come from a separate build without the feature; hybrid numbers come from a PQ-enabled build. All microbenchmarks are driven by Criterion [10], with per-benchmark warm-up, outlier detection, and bootstrapped 95% confidence intervals. For the handshake benchmark, two **Tunn** instances exchange bytes in-process via function calls on the same machine, with no sockets in the loop, so the measurement reflects pure cryptographic cost. For transport throughput, `iperf3` is run in two setups (M4 loopback and M4-to-Pi cross-device over Wi-Fi); each figure is the mean of ten independent 15-second runs, reported with a 95% confidence interval computed from the sample standard deviation under a normal approximation.

7.1 Handshake latency

Table 1: Handshake latency across configurations and platforms (loopback, Criterion sample size 500). Each cell shows the bootstrapped per-iteration point estimate followed by the 95% CI.

Configuration	Platform	Latency (μ s, [95% CI])
Vanilla	M4	153.55 [153.32, 153.77]
PSK-slot	M4	154.99 [154.75, 155.24]
Hybrid	M4	246.69 [246.39, 246.99]
Vanilla	Raspberry Pi 5	1312.0 [1311.9, 1312.1]
PSK-slot	Raspberry Pi 5	1312.0 [1311.9, 1312.1]
Hybrid	Raspberry Pi 5	1644.0 [1643.8, 1644.2]
Vanilla	Ryzen 7 5700X	279.64 [278.83, 280.50]
PSK-slot	Ryzen 7 5700X	281.20 [280.38, 282.07]
Hybrid	Ryzen 7 5700X	414.91 [413.93, 415.98]

On the M4 the hybrid adds about 93 μ s over vanilla (+61%). The isolated ML-KEM operations (KeyGen + Encaps + Decaps $\approx 72 \mu$ s, Table 3) account for most of it; the remaining $\sim 21 \mu$ s is bookkeeping around the KEM: an extra BLAKE2s pass over the 2272 bytes of PQ transcript material, the extra HMAC-BLAKE2s mixing step, larger heap buffers. PSK-slot lands about 1.4 μ s (under 1%) above vanilla, consistent with the handful of extra HMAC calls it adds; Criterion’s CIs are tight enough on this platform to resolve that small gap even though it is negligible in absolute terms.

The Pi tells a different story: the hybrid adds about 332 μ s, but only +25%, because the classical baseline is dominated by X25519. A single DH takes 192.54 μ s there, and the six fresh DH operations per handshake (BoringTun caches the static-static result) alone account for $\sim 1155 \mu$ s of the 1312 μ s vanilla figure. The three ML-KEM operations explain $\sim 282 \mu$ s of the hybrid gap, payload movement the rest.

The Ryzen sits between the two in raw speed and proportional overhead (vanilla 279.64 μ s, hybrid 414.91 μ s, +48%), with the ML-KEM operations again explaining most of the gap. It serves mainly as a control: the implementation produces the same shape of result on x86_64, with hybrid overhead bounded by ML-KEM cost rather than anything ARM-specific.

A caveat: the loopback setup measures cryptographic cost only. Over a real connection, handshake latency is dominated by RTT, not by the sub-millisecond difference between configurations — Section 7.9 shows this directly.

7.2 Handshake packet sizes and transport throughput

Table 2: Handshake packet sizes and post-handshake transport throughput (iperf3; throughput is the mean of ten 15-second runs, with 95% CIs given in the text).

Config.	Init (B)	Resp (B)	Total (B)	Config.	Setup	Mbps
Vanilla	148	92	240	Vanilla	M4 loopback	478.2
PSK-slot	148	92	240	Hybrid	M4 loopback	469.2
Hybrid	1332	1180	2512	Vanilla	M4 $\rightarrow$ Raspberry Pi 5	85.4
				Hybrid	M4 $\rightarrow$ Raspberry Pi 5	79.4

PSK-slot packet sizes equal vanilla because the PSK never appears on the wire. The hybrid carries the encapsulation key in the initiation (+1184 B) and the ciphertext in the response (+1088 B), 2272 bytes of additional handshake traffic fixed by the ML-KEM-768 specification.

Throughput is statistically indistinguishable across configurations: in both setups the vanilla and hybrid 95% confidence intervals overlap (M4 loopback: vanilla 478.2 [473.4, 483.1] vs hybrid 469.2 [462.3, 476.0]; cross-device over Wi-Fi: vanilla 85.4 [79.3, 91.5] vs hybrid 79.4 [73.6, 85.2], where the run-to-run spread reflects the wireless link rather than the Pi’s crypto capacity). This parity is the only reasonable outcome: all three configurations share the same ChaCha20-Poly1305 data plane once the handshake is done, and any difference would point to an implementation bug.

7.3 ML-KEM and X25519 microbenchmarks

Table 3: ML-KEM-768 and X25519 operation microbenchmarks (Criterion, sample size 1000, point estimate followed by 95% CI).

Operation	M4 (μ s)	Raspberry Pi 5 (μ s)	Ryzen 5700X (μ s)
ML-KEM-768 KeyGen	23.88 [23.86, 23.89]	81.61 [81.60, 81.62]	35.83 [35.75, 35.93]
ML-KEM-768 Encaps	20.67 [20.65, 20.68]	84.04 [84.03, 84.04]	33.88 [33.76, 34.01]
ML-KEM-768 Decaps	27.52 [27.49, 27.55]	116.39 [116.28, 116.62]	45.54 [45.43, 45.66]
X25519 KeyGen	8.63 [8.61, 8.64]	57.98 [57.97, 57.98]	12.44 [12.41, 12.48]
X25519 DH	19.91 [19.89, 19.94]	192.54 [192.53, 192.55]	39.52 [39.41, 39.63]

Relative performance depends heavily on the platform. On the M4 the two primitives are roughly comparable per operation: X25519 DH and ML-KEM Encaps land within a microsecond of each other, and X25519 clearly wins only at keypair generation. On the Pi the relationship flips: X25519 DH balloons to 192.54 μ s while all three ML-KEM operations sit below it — broadly matching the eBACS cycle-count prediction that ML-KEM should be 2–3 $\times$ faster than X25519. The Ryzen sits between the two and is closer in shape to the M4, which supports reading the Pi gap as platform-specific: `x25519-dalek` has a fast AVX2 backend (helping the Ryzen) and a fast scalar path (handled well by the M4’s wide core), but lacks a NEON port for the Cortex-A76, so the Pi falls back to a slow scalar implementation while ML-KEM’s NTT-based arithmetic maps onto the integer pipeline either way.

7.4 ML-KEM parameter set sweep

FIPS-203 defines three parameter sets: ML-KEM-512 (NIST level 1), ML-KEM-768 (level 3), and ML-KEM-1024 (level 5). The choice is a three-way tradeoff between security margin, per-handshake compute cost, and on-wire message size. The compute side was measured by running the same Criterion harness against all three sets on each platform.

Table 4: ML-KEM operation latency across all three FIPS-203 parameter sets and platforms (Criterion, sample size 1000, point estimate in microseconds). Bootstrapped 95% CIs are uniformly tight (typically a few tens of nanoseconds wide).

Param set	Platform	Keygen	Encaps	Decaps
ML-KEM-512	M4	14.69	12.60	17.45
ML-KEM-512	Raspberry Pi 5	48.32	51.64	74.70
ML-KEM-512	Ryzen 7 5700X	20.94	20.27	28.88
ML-KEM-768	M4	23.88	20.67	27.52
ML-KEM-768	Raspberry Pi 5	81.61	84.04	116.39
ML-KEM-768	Ryzen 7 5700X	35.83	33.88	45.54
ML-KEM-1024	M4	37.31	31.25	40.89
ML-KEM-1024	Raspberry Pi 5	125.61	127.80	167.42
ML-KEM-1024	Ryzen 7 5700X	56.09	51.41	66.44

Scaling between security levels is roughly linear in NIST category on all three platforms: going from ML-KEM-512 to ML-KEM-1024 costs about $2.5\times$ more per op. So the parameter-set choice does not buy or cost order-of-magnitude factors of latency, and at handshake scale any of the three is well within the budget the X25519 baseline already sets. ML-KEM-1024 on the Pi is the worst case ($167\ \mu\text{s}$ Decaps), still cheaper than a single X25519 DH on the same hardware.

Table 5: Hybrid handshake datagram sizes by ML-KEM parameter set.

Param set	EK (B)	CT (B)	Hybrid init (B)	Hybrid resp (B)
ML-KEM-512	800	768	948	860
ML-KEM-768	1184	1088	1332	1180
ML-KEM-1024	1568	1568	1716	1660

Where the choice actually matters is the wire. The 1280-byte IPv6 minimum MTU is the load-bearing threshold: only ML-KEM-512 fits under it without IP-level fragmentation. At a standard 1500-byte Ethernet MTU, both ML-KEM-512 and ML-KEM-768 fit comfortably; ML-KEM-1024’s 1716-byte initiation always fragments. Picking ML-KEM-768 gives NIST level 3 while remaining unfragmented on any normal Ethernet path.

7.5 Path-MTU sweep

The hybrid initiation is 1332 bytes (Table 2), which fits a 1500-byte Ethernet path comfortably but does not fit any path whose effective MTU is below roughly 1360 bytes: the 1332-byte initiation plus its IP and UDP headers. The testbed brings up two Linux network namespaces connected by a veth pair, runs BoringTun in each, and sweeps the veth MTU across values that straddle the hybrid initiation size. Each cell is 10 cold trials; latency is the first-packet ping RTT, which subsumes the handshake cost.

Table 6: Handshake success rate and first-packet latency across a path-MTU sweep on the Raspberry Pi 5. The *drop_frags* column attempts an iptables fragment-drop rule on the responder; see below for why it is silently inert.

Mode	MTU (B)	Drop frags	Successes	p50 RTT (ms)
Vanilla	1500	no	10/10	1.70
Hybrid	1500	no	10/10	2.09
Vanilla	1500	yes	10/10	2.58
Hybrid	1500	yes	10/10	2.09
Vanilla	1400	no	10/10	1.71
Hybrid	1400	no	10/10	3.26
Vanilla	1400	yes	10/10	2.50
Hybrid	1400	yes	10/10	3.27
Vanilla	1300	no	10/10	2.64
Hybrid	1300	no	10/10	3.10
Vanilla	1300	yes	10/10	1.71
Hybrid	1300	yes	10/10	2.12
Vanilla	1280	no	10/10	2.26
Hybrid	1280	no	10/10	2.10
Vanilla	1280	yes	10/10	1.76
Hybrid	1280	yes	10/10	3.13

The headline: the hybrid handshake completes 10/10 at every cell, including those where the 1332-byte initiation exceeds the path MTU and must be fragmented by the kernel. p50 latency stays in a 1.7–3.3 ms band across the sweep, with the hybrid 0.5–1 ms above vanilla — the in-process ML-KEM cost of Table 1 carried into a real socket path. There is no cliff at the fragmentation boundary (~ 1360 bytes of path MTU): kernel-level IP fragmentation is transparent to userspace WireGuard and adds at most a few hundred microseconds on this hardware.

A methodology note on the *drop_frags* column: the iptables rule intended to simulate a fragment-dropping middlebox (`-f -j DROP` on INPUT) is silently inert, because any non-trivial netfilter ruleset loads `nf_defrag_ipv4`, which reassembles fragments at the conntrack stage — before the filter table ever sees them. Genuinely testing fragment-hostile middleboxes would require a pre-conntrack hook or a third forwarding namespace, neither in this testbed. The supported claim is therefore the more limited but honest one: the hybrid handshake survives IP-layer fragmentation cleanly across all measured MTUs, with the fragment-hostile-middlebox case left for future work.

7.6 RTT and loss

With MTU pinned at 1500 (no fragmentation pressure), the testbed attaches `tc netem` qdiscs to both veth endpoints to inject symmetric one-way delay and packet loss, and re-runs the cold-handshake trial across a four-by-three matrix of delay $\in \{0, 10, 50, 100\}$ ms and loss $\in \{0, 0.1, 1\}\%$. Twenty trials per cell.

Table 7: Hybrid and vanilla handshake performance under injected RTT and loss on the Raspberry Pi 5. p50 / p95 are over successful trials; the *Succ.* column shows trials that finished within the 5-second ping timeout.

Delay (ms)	Loss (%)	Vanilla			Hybrid		
		Succ.	p50 (ms)	p95 (ms)	Succ.	p50 (ms)	p95 (ms)
0	0	20/20	1.71	2.53	20/20	2.09	2.13
0	0.1	20/20	2.52	2.73	20/20	3.07	3.32
0	1	20/20	1.81	2.70	20/20	3.27	3.43
10	0	20/20	42.6	42.7	20/20	43.3	43.5
10	0.1	20/20	42.7	42.7	20/20	43.3	43.5
10	1	20/20	42.7	42.8	20/20	43.3	43.5
50	0	20/20	202	203	20/20	203	203
50	0.1	20/20	202	203	20/20	203	203
50	1	19/20	202	303	19/20	203	1319
100	0	20/20	403	403	20/20	403	403
100	0.1	20/20	403	403	19/20	403	603
100	1	19/20	403	603	20/20	403	403

Median latency tracks RTT cleanly, as it should: at d ms one-way delay the first-packet ping pays one handshake round-trip plus one ping round-trip, so p50 sits just above $4d$. The hybrid is consistently 0.5–1 ms above vanilla across every RTT band — the ML-KEM cost again, unaffected by the link.

The interesting cells are at the high end. At $50\text{ ms} \times 1\%$, both modes drop to 19/20 successes, the same per-trial failure rate, and the hybrid p95 stretches to 1319 ms against vanilla’s 303 ms: the signature of a retry firing. The gap between the two tails should not be over-read: at 1500-byte MTU both modes send the same number of handshake datagrams and `netem` drops whole packets, so with a single loss event per 20 trials the p95 lands on the one trial that retried, and the figure is dominated by where in the retry sequence that particular loss happened. The 100 ms cells at 19/20 are within Bernoulli noise for 20 samples. The deployment takeaway: on ordinary links the hybrid behaves like vanilla; under combined high RTT and non-trivial loss the failure *rate* is unchanged but worst-case recovery can take seconds — a tail that matters for re-handshake budgets in long-lived sessions, not for the dominant first-connect case.

7.7 Per-peer memory footprint

A separate concern from handshake speed, especially for IoT and edge deployments, is how much memory each peer state costs. BoringTun is a userspace daemon, so per-peer state lives on the heap and on the stack of the `Tunn` struct rather than in kernel memory. A small probe (`boringtun/examples/memory_probe.rs`) prints `size_of` for the relevant structs and samples peak RSS while holding $N \in \{10, 100, 1000\}$ live `Tunn` instances.

Table 8: Compile-time per-peer struct sizes. Identical across all measured platforms (Apple M4, Raspberry Pi 5, Ryzen 7 5700X via WSL2).

Type	Vanilla (B)	Hybrid (B)	Delta (B)
<code>Tunn</code>	11,040	17,424	+6,384
<code>Handshake</code>	552	6,936	+6,384

The entire 6384-byte `Tunn` delta sits inside the `Handshake` struct, which holds two `HandshakeState` slots (current and previous). Each grew by about 3192 bytes, dominated by the inline `Option<DecapsulationKey768>` — the FIPS-203 decapsulation key is a 2400-byte

array carried by value — in the `InitSent` variant. Struct sizes are identical across all three platforms because Rust’s layout is portable; the overhead is a fixed per-peer cost.

On the dynamic side, the M4 probe shows per-peer resident-set cost converging to about 6.9 KB at $N = 1000$, within 8% of the struct delta (the remainder is allocator chunk overhead). A concentrator holding 1000 hybrid peers thus spends about 6.9 MB more RAM than its vanilla counterpart, under 2% of total RAM even on IoT-class hardware with 100–512 MB. The Linux probes are less informative: the binaries’ large static footprints mean `ru_maxrss` never budes as N grows, so per- N scaling disappears below the noise floor there, though the cross-build delta (0.5–0.7 MB of `ml-kem` static data) survives. The portable result is the struct delta, which the M4 measurements ground in a real per-peer number.

7.8 DoS asymmetry under handshake flood

WireGuard’s handshake messages carry two MACs: MAC1 (HMAC over the message, keyed by a hash of the responder’s static public key) and MAC2 (cookie-bound, used only under signalled overload). MAC1 is the first line of defence against handshake-init floods: the rate limiter verifies it before committing to anything more expensive, and in the hybrid the expensive path now includes an ML-KEM Encaps on top of the X25519 operations, so the asymmetry between rejecting a flood packet and processing it matters more. To measure what a responder actually spends per packet under flood, a small flooder (`boringtun/examples/handshake_flood.rs`) emits init packets at line rate in two variants: **valid MAC1** (the packet passes MAC1 verification and proceeds into the load-dependent processing path) and **invalid MAC1** (rejected at the top of the receive path).

Each cell is a 10-second saturating flood from a single-threaded flooder against a single Pi 5 responder, with fresh keypairs on every packet so the responder cannot fast-path on session caches. That freshness is itself expensive to produce — the flooder performs real keypair generation and MAC computation per packet — so a single flooder core saturates at roughly 1,900 packets per second in vanilla mode and 1,650 in hybrid mode, far above BoringTun’s handshake admission threshold of 100 per second. CPU time is sampled from `/proc/<pid>/stat` before and after the window and divided by the number of packets the flooder sent.

Table 9: Responder CPU cost per received init packet under a saturating flood, by handshake mode and MAC1 validity, on the Raspberry Pi 5.

Mode	MAC1	Packets sent	CPU (s)	CPU/pkt (μ s)
Vanilla	invalid	19,440	0.060	3.09
Vanilla	valid	19,427	0.290	14.93
Hybrid	invalid	16,530	0.100	6.05
Hybrid	valid	16,491	0.390	23.65

Reading the *valid* rows correctly requires accounting for WireGuard’s second defence layer, because at these rates the responder sits permanently in the under-load regime. BoringTun’s rate limiter admits at most 100 handshakes per second past the MAC1 check without a cookie; every further valid-MAC1 packet receives only a cookie reply, and since the flooder never completes the cookie round-trip, no MAC2-authenticated retry follows. The admitted packets do not reach ML-KEM either: the responder performs one X25519 DH to decrypt the initiator’s static key, finds no matching configured peer, and drops the packet — Encaps runs only when a response is being built for a recognized peer. The *valid*-row figures are therefore not the cost of full handshake cryptography (a single X25519 DH alone costs 192.54 μ s on this hardware, Table 3); they are the cost of MAC1 verification plus a cookie reply for the vast majority of packets, plus the rate-limited residue of single-DH work. The accounting closes: at the mea-

sured 1,943 packets per second, ~ 100 admitted packets at $\sim 195 \mu\text{s}$ each plus $\sim 1,840$ cookie replies at a few microseconds each predict ≈ 29 ms of responder CPU per second, matching the measured 0.290 s over the 10-second vanilla window.

The security-relevant finding is stronger than the MAC1-ordering check the experiment was designed for: under a saturating flood of well-formed, valid-MAC1 initiations, the responder performed *zero* ML-KEM operations, because MAC1 verification and cookie-based rate limiting together gate all post-quantum work behind a round-trip the attacker must complete. The within-mode ratios ($4.8\times$ for vanilla, $3.9\times$ for hybrid) compare the pure MAC1 reject against this verify-plus-cookie path. The hybrid build still pays more per rejected packet in absolute terms ($6.05 \mu\text{s}$ vs vanilla’s $3.09 \mu\text{s}$, a $2.0\times$ gap), but that comes from parsing the larger 1332-byte initiation and from the MAC1 computation hashing more bytes, not from running any ML-KEM operation.

A practical reading: at the worst measured rate ($23.65 \mu\text{s}$ per packet, hybrid valid), the Pi 5 spends roughly 3.9% of one core absorbing a $\sim 1,650$ -pps flood, well within the headroom needed to keep serving legitimate handshakes. What this experiment does not bound is an adversary who completes cookie round-trips from genuine source addresses to present valid MAC2s, thereby forcing full handshake processing (including Encaps); quantifying that MAC2-authenticated path, and handshake completion for legitimate peers under sustained flood, is left as future work.

7.9 End-to-end validation over the public internet

The measurements above isolate individual costs under controlled conditions; a final check is whether the implementation simply works, end to end, on a real internet path. For this, three tunnels — vanilla, PSK-slot (with the PSK established by a real cross-host ML-KEM-768 exchange via `pq-psk-tool`), and hybrid — were brought up in parallel between a laptop in Romania and a cloud VM in a US-East data centre, a transcontinental path crossing the public internet. The exercise was run live, as the demonstration accompanying the thesis defense this work is based on.

Each tunnel was verified in three ways. First, the handshake of every variant was captured on the physical interface with `tcpdump`; the observed on-wire message sizes matched the expected values exactly (148/92 B for vanilla and PSK-slot, 1332/1180 B for the hybrid, cf. Table 2), and the 1332-byte hybrid initiation traversed the path without incident. Second, application payloads (images and text) were sent through each tunnel to a receiver bound to the VM’s tunnel-interface address and echoed back, with matching SHA-256 digests at both ends confirming byte-for-byte round trips through the encrypted tunnel. Third, wall-clock handshake times were indistinguishable across the three variants, as predicted by Section 7.1: over a path with an RTT of roughly 140–150 ms, the sub-millisecond ML-KEM cost vanishes entirely into network noise.

This is a deployment check rather than a benchmark, but it closes the loop the controlled experiments leave open: the hybrid handshake, with its fragmentation-prone initiation and new message types, negotiates a real consumer uplink, NAT, and a commercial cloud network without any accommodation: the observable cost of the post-quantum upgrade on a real path is message size, not time.

8 Discussion

8.1 Choosing between PSK-slot and hybrid

The two approaches occupy genuinely different positions in the security/complexity tradeoff space. For operators who need post-quantum protection today with minimal disruption, the PSK-slot approach is the pragmatic choice: no WireGuard code changes, compatibility with

any existing client and server, incremental rollout. Rosenpass and ExpressVPN’s PSK-over-TLS deployment show it works at scale [15, 21].

The hybrid earns its extra 800 lines through per-handshake forward secrecy: every session gets a fresh ML-KEM keypair, so key material compromised after the fact exposes nothing, whereas a single PSK compromise can expose months of traffic. It is also better aligned with where things are going: organizations facing the 2030/2035 NIST deadlines will eventually need a WireGuard whose key exchange is quantum-resistant without depending on external key management.

8.2 Deployment considerations

MTU management is the most pressing operational concern. Paths with an effective MTU below roughly 1360 bytes fragment the hybrid initiation. The sweep in Section 7.5 shows the handshake completes cleanly across MTUs from 1280 to 1500 when the path tolerates fragments, and the WAN check in Section 7.9 adds one real-world data point; what remains untested is the path operators actually worry about — a middlebox that silently drops IP fragments. Prudence still says to assume such paths exist and push toward application-level segmentation or PMTUD-driven parameter selection. One thing that does *not* help, despite being the obvious first reflex, is lowering the WireGuard interface MTU: that shrinks the encapsulated data packets, not the fixed-size handshake messages.

Interoperability is a constraint: both endpoints must run the hybrid-capable BoringTun, since a vanilla peer drops the unrecognized message types (5 and 6) at type dispatch. Some form of capability negotiation, such as a reserved handshake field or simply an out-of-band configuration flag, would be needed for gradual rollout; an engineering problem, not a fundamental one.

Key management is actually simpler with the hybrid than with the PSK-slot approach: X25519 static keys are managed as before, and the ML-KEM ephemeral keys are generated and discarded within each handshake. There is nothing new to distribute or rotate.

Performance on constrained hardware matters for edge and IoT deployments, and the Pi 5 numbers collectively clear the bar: sub-millisecond handshake overhead (far below any WAN RTT), a fixed 6.4 KB of extra per-peer state — roughly 6.9 MB for a thousand peers — and $\sim 3.9\%$ of one core under a saturating init flood, with all ML-KEM work gated behind MAC1 verification and cookie-based rate limiting. None of these signal a meaningful deployability barrier at the Pi-class hardware tier.

8.3 Authentication agility and future work

Authentication in this paper remains classical (X25519 static keys), which means it is quantum-vulnerable. A future version could extend authentication to ML-DSA (FIPS 204) signatures, or use static ML-KEM keys as PQ-WireGuard and Hybrid-WireGuard do; either significantly increases key-management complexity (ML-DSA-65 public keys are 1952 bytes, against 32 for X25519). Leaving authentication classical is a deliberate choice, consistent with NIST’s guidance [18] that key-agreement migration (where HNDL applies) is more urgent than signature migration (where past signatures cannot be retroactively forged).

Rosenpass integration. Combining Rosenpass-managed PSKs with the hybrid handshake would give layered post-quantum security; careful analysis is needed to confirm the double-layering introduces no new weaknesses.

Formal verification. The informal security argument should be supplemented by a formal proof; the eCK-PFS-PSK model of Hülising et al. [11] and the Sapic+ approach of Lafourcade et al. [13] provide templates.

Parameter set agility. The implementation pins ML-KEM-768. Operator-side selection of ML-KEM-512 or -1024 is backed by concrete numbers from Section 7.4: only ML-KEM-512

avoids fragmentation below the 1280-byte IPv6 minimum, ML-KEM-768 fits standard Ethernet, ML-KEM-1024 always fragments, and compute cost scales roughly linearly in security category while staying small against the X25519 baseline.

MTU fragmentation handling. Two alternatives merit investigation: application-level segmentation (ML-KEM material in a separate datagram, one extra round trip, no IP fragmentation) and PMTUD-driven parameter negotiation. Both add protocol complexity and would require careful design to avoid downgrade attacks, which is also why any parameter agility should stay at the operator level rather than per-connection, preserving WireGuard’s deliberate lack of cipher negotiation.

9 Conclusion

This paper presented a hybrid post-quantum key exchange for WireGuard, integrating ML-KEM-768 alongside X25519 in the Noise IK handshake of BoringTun, Cloudflare’s production Rust userspace WireGuard — to our knowledge the first FIPS 203-compliant hybrid WireGuard built on a production codebase. The core idea is straightforward: the initiator sends its ML-KEM encapsulation key in the first handshake message, the responder returns the ciphertext in the second, and both shared secrets are mixed sequentially into the Noise chaining key via HMAC-BLAKE2s — structurally the NIST SP 800-56C concatenate-then-KDF pattern, secure as long as either component remains unbroken, and, because the ML-KEM keypair is fresh per handshake, providing the post-quantum forward secrecy that the PSK-slot baseline cannot.

The central finding is how little the migration costs. The whole intervention is roughly 800 feature-gated lines, most of it confined to the handshake module, with the data plane untouched. Across a performance laptop, a constrained single-board computer, and an x86_64 server-class control, the added computation stays under half a millisecond; throughput is unchanged; per-peer memory grows by a fixed 6.4 KB; WireGuard’s flood defence carries over intact; and under injected RTT and loss the hybrid behaves like vanilla in the median, paying only longer worst-case retry tails. The one real cost is on the wire: 2272 extra handshake bytes, pushing the initiation past the IPv6 minimum MTU, and the measured MTU sweep plus an end-to-end deployment between Romania and a US-East cloud host show that IP-layer fragmentation carries even that cost transparently on real paths. Fragment-hostile middleboxes remain the open operational risk, with application-level segmentation as future work.

With NIST’s 2030 deprecation deadline for classical key exchange approaching [18] and harvest-now-decrypt-later no longer hypothetical, post-quantum key exchange for VPNs is becoming an operational requirement rather than a research exercise. The evidence here suggests the migration need not be disruptive: for WireGuard, a minimally invasive hybrid upgrade delivers standardized post-quantum key exchange at a cost measured in bytes, not milliseconds.

Artefact availability. Source code for the modified BoringTun (with the pq Cargo feature), the pq-psk-tool binary, the Criterion benchmark harness, the network-namespace testbeds for MTU and RTT/loss sweeps, the handshake-flood DoS example, and the memory probe is available at <https://github.com/mihaicristianfarcas/pq-boringtun>.

Declaration of generative AI use. During the preparation of this work the author used Claude (Anthropic’s large language model) via the Claude Code CLI tool as a coding assistant while implementing the hybrid handshake and PSK-slot tool in Rust, for designing and interpreting the benchmarks, and as an editor to tighten the prose and catch places where the written descriptions had drifted from what the code actually does. The author reviewed and edited all content and takes full responsibility for it.

References

- [1] Yawning Angel, Benjamin Dowling, Andreas Hülsing, Peter Schwabe, and Florian Weber. Post-quantum Noise. IACR ePrint 2022/539, 2022. URL <https://eprint.iacr.org/2022/539>. Framework for converting Noise patterns to post-quantum using KEMs.
- [2] Joppe Bos, Léo Ducas, Eike Kiltz, Tancrede Lepoint, Vadim Lyubashevsky, John M. Schanck, Peter Schwabe, Gregor Seiler, and Damien Stehlé. CRYSTALS-Kyber: A CCA-secure module-lattice-based KEM. In *Proceedings of the 2018 IEEE European Symposium on Security and Privacy (EuroS&P)*, pages 353–367. IEEE, 2018. doi: 10.1109/EuroSP.2018.00032.
- [3] Cloudflare, Inc. BoringTun: Userspace WireGuard implementation in Rust. GitHub repository, 2024. URL <https://github.com/cloudflare/boringtun>. Production-grade userspace WireGuard implementation deployed on millions of devices.
- [4] Jason A. Donenfeld. WireGuard: Next generation kernel network tunnel. In *Proceedings of the 2017 Network and Distributed System Security Symposium (NDSS)*. Internet Society, 2017. doi: 10.14722/ndss.2017.23160.
- [5] Jason A. Donenfeld and Kevin Milner. Formal verification of the WireGuard protocol. Technical report, WireGuard, 2018. URL <https://www.wireguard.com/papers/wireguard-formal-verification.pdf>. Tamarin-based symbolic proof of WireGuard’s session-key secrecy and authentication properties.
- [6] Benjamin Dowling and Kenneth G. Paterson. A cryptographic analysis of the WireGuard protocol. In *Applied Cryptography and Network Security – ACNS 2018*, volume 10892 of *Lecture Notes in Computer Science*, pages 3–21. Springer, 2018. doi: 10.1007/978-3-319-93387-0_1. Computational security proof for WireGuard.
- [7] Federico Giacon, Felix Heuer, and Bertram Poettering. KEM combiners. In *Public-Key Cryptography – PKC 2018*, volume 10769 of *Lecture Notes in Computer Science*, pages 190–218. Springer, 2018. doi: 10.1007/978-3-319-76578-5_7. Security proof for concatenate-then-KDF hybrid construction. IACR ePrint 2018/024, <https://eprint.iacr.org/2018/024>.
- [8] Craig Gidney and Martin Ekerå. How to factor 2048-bit RSA integers in 8 hours using 20 million noisy qubits. *Quantum*, 5:433, 2021. doi: 10.22331/q-2021-04-15-433.
- [9] Keitaro Hashimoto, Shuichi Katsumata, Emmanuel Niot, and Thom Wiggers. Revised PQ-WireGuard with reinforced KEMs. In *Proceedings of the 2026 IEEE Symposium on Security and Privacy (S&P)*. IEEE, 2026. Introduces Rebar RKEM construction. Preprint available at <https://eprint.iacr.org/2025/1758.pdf>.
- [10] Brook Heisler. Criterion.rs: Statistics-driven microbenchmarking in Rust. <https://github.com/bheisler/criterion.rs>, 2024. Benchmarking library with bootstrapped confidence intervals and outlier detection.
- [11] Andreas Hülsing, Kai-Chun Ning, Peter Schwabe, Florian Weber, and Philip R. Zimmermann. PQ-WireGuard: Post-quantum key exchange for WireGuard protocol. In *Proceedings of the 2021 IEEE Symposium on Security and Privacy (S&P)*, pages 304–321. IEEE, 2021. doi: 10.1109/SP40001.2021.00031.
- [12] Hugo Krawczyk and Pasi Eronen. RFC 5869: HMAC-based extract-and-expand key derivation function (HKDF). Internet Requests for Comments, 2010.

- [13] Pascal Lafourcade, Dhekra Mahmoud, and Sylvain Ruhault. A tale of two worlds, a formal story of WireGuard hybridization. In *Proceedings of the 34th USENIX Security Symposium (USENIX Security 25)*, pages 4937–4956. USENIX Association, 2025. URL <https://www.usenix.org/conference/usenixsecurity25/presentation/lafourcade>. Formal analysis of Hybrid-WireGuard using Sapic+/ProVerif/DeepSec/Tamarin. IACR ePrint 2025/1179.
- [14] Adeline Langlois and Damien Stehlé. Worst-case to average-case reductions for module lattices. *Designs, Codes and Cryptography*, 75(3):565–599, 2015. doi: 10.1007/s10623-014-9938-4.
- [15] Peter Membrey and Daan Beyel. Hybrid post-quantum WireGuard via TLS PSK delivery: A production deployment at scale. *Engineering Archive (engrXiv)*, 2025. URL <https://engrxiv.org/preprint/view/5020>. ExpressVPN’s production deployment of PSK-based post-quantum WireGuard.
- [16] National Institute of Standards and Technology. NIST special publication 800-56c rev. 2: Recommendation for key-derivation methods in key-establishment schemes, 2020.
- [17] National Institute of Standards and Technology. FIPS 203: Module-lattice-based key-encapsulation mechanism standard. Federal information processing standards publication, U.S. Department of Commerce, August 2024.
- [18] National Institute of Standards and Technology. NIST IR 8547: Transition to post-quantum cryptography standards (initial public draft), 2024. Outlines 2030 deprecation and 2035 disallowance timeline for classical key exchange.
- [19] Trevor Perrin. The Noise protocol framework. <https://noiseprotocol.org/>, 2018.
- [20] Rosenpass Contributors. Rosenpass: Post-quantum secure key exchange for WireGuard. GitHub repository, 2024. URL <https://github.com/rosenpass/rosenpass>.
- [21] Rosenpass Project. Rosenpass: Post-quantum secure VPN key exchange. <https://rosenpass.eu/>, 2024. Open-source post-quantum key exchange daemon for WireGuard.
- [22] Peter W. Shor. Algorithms for quantum computation: Discrete logarithms and factoring. In *Proceedings 35th Annual Symposium on Foundations of Computer Science (FOCS)*, pages 124–134. IEEE, 1994. doi: 10.1109/SFCS.1994.365700.
- [23] Douglas Stebila, Scott Fluhrer, and Shay Gueron. Hybrid key exchange in TLS 1.3. Internet-Draft draft-ietf-tls-hybrid-design-14, 2024. URL <https://datatracker.ietf.org/doc/html/draft-ietf-tls-hybrid-design-14>. Work in Progress.